企业信息安全管理规范

第一章 总则

为规范公司信息系统的安全管理，保障业务数据在采集、传输、存储和处理过程中的机密性与完整性，依据国家有关法律法规及行业标准，结合公司实际情况，制定本规范。本规范适用于公司全体在职员工、外包人员及第三方合作方。

公司设立信息安全管理委员会，由分管副总裁担任主任委员，信息安全部作为日常执行机构，负责安全策略的制定、风险评估的组织以及安全事件的响应处置。各部门负责人为本部门信息安全第一责任人。

第二章 账号与权限管理

所有业务系统账号必须实名绑定，禁止共享账号或将账号借予他人使用。员工离职或岗位调整时，人力资源部门应在办理手续当日通知信息安全部，由信息安全部在两个工作日内完成权限回收。

权限授予遵循最小必要原则。涉及生产环境数据库、核心业务配置的权限，须经部门负责人与信息安全部双重审批，并保留完整的审批记录，记录保存期限不少于三年。The audit trail must be immutable and retained for compliance review.

第三章 数据分类分级

公司数据按敏感程度划分为公开、内部、秘密、机密四个等级。机密级数据仅限经授权人员在受控环境中访问，禁止通过即时通讯工具、个人邮箱或移动存储介质进行传输。